CISSP 300

Domain 3:
Security Architecture and Engineering



AL NAFI,
A company with a focus on education,
wellbeing and renewable energy.

© 2018 Al-Nafi. All Rights Reserved.

Hadith # 21 The example of a scholar

Jundub reported, the Prophet (Peace be Upon Him said):

"The example of the scholar who teaches people the good, but forgets himself, is the example of the lantern which gives light to people while it burns itself out."

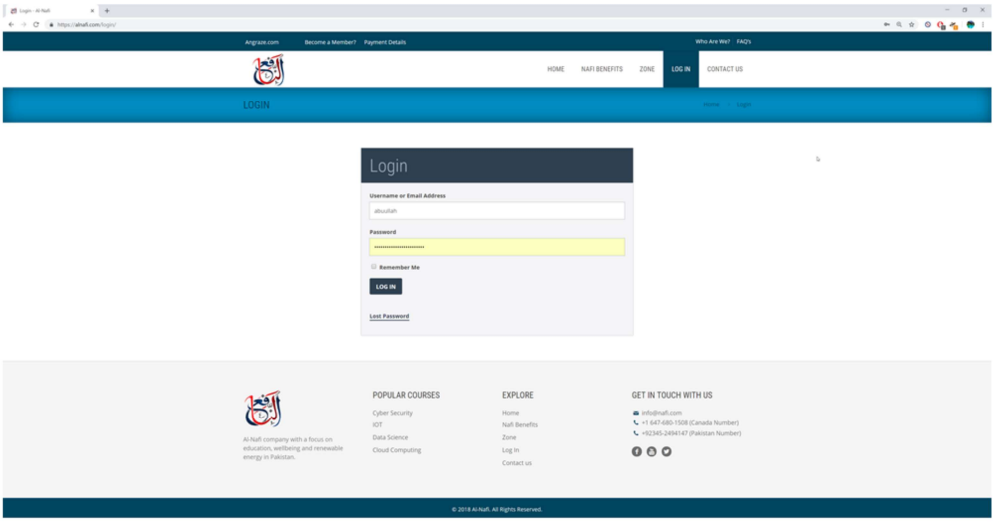
(at-Tabarani: ad-Diya' al-Maqdisi)

How Nafi Members Study!

1. Please subscribe to our YouTube channel https://www.youtube.com/channel/UC2yAW4Oq27r1yuRE8ePKRvA
2. Follow us on Facebook https://www.facebook.com/info.alnafi/
3. Follow us on Twitter https://twitter.com/nafiPakistan
4. All Nafi members MUST study on the portal https://alnafi.com/login/ and connect using your Nafi member username and password
5. Once on the portal they can follow their classes by:
    - watching videos
    - asking questions
    - attempting quizzes and flash cards
    - studying official Nafi notes
    - taking their own notes online just like evernote
    - keep track of their studies long with many more features

© 2018 Al-Nafi. All Rights Reserved.

Members Please connect to our portal



© 2018 Al-Nafi. All Rights Reserved.



Domain 3:
Security Architecture and Engineering

3.1 Implement and manage engineering processes using secure design principles

3.2 Understand the fundamental concepts of security models

3.3 Select controls based upon systems security requirements

3.4 Understand security capabilities of information systems (e.g., memory protection, Trusted Platform Module (TPM), encryption/decryption)

© 2018 Al-Nafi. All Rights Reserved.

The goal of the Security Architecture and Engineering domain is to provide you with concepts, principles, structures, and standards used to design, implement, monitor, and secure operating systems, equipment, networks, applications, and those controls used to enforce various levels of confidentiality, integrity, and availability.



Domain 3:
Security Architecture and Engineering

3.5 Assess and mitigate the vulnerabilities of security architectures, designs, and solution Elements

3.6 Assess and mitigate vulnerabilities in web-based systems

3.7 Assess and mitigate vulnerabilities in mobile systems

3.8 Assess and mitigate vulnerabilities in embedded devices

© 2018 Al-Nafi. All Rights Reserved.



Domain 3: Security Architecture and Engineering

3.9 Apply cryptography

- »» Client-based systems
- »» Server-based systems
- »» Database systems
- »» Cryptographic systems
- »» Industrial Control Systems (ICS)
- »» Cloud-based systems
- »» Distributed systems
- »» Internet of Things (IoT)

© 2018 Al-Nafi. All Rights Reserved.



Domain 3:
Security Architecture and Engineering

3.10 Apply security principles to site and facility design

3.11 Implement site and facility security controls

- »» Wiring closets/intermediate distribution facilities
- »» Server rooms/data centers
- »» Media storage facilities
- »» Evidence storage
- »» Restricted and work area security
- »» Utilities and Heating, Ventilation, and Air Conditioning (HVAC)
- »» Environmental issues
- »» Fire prevention, detection, and suppression

© 2018 Al-Nafi. All Rights Reserved.

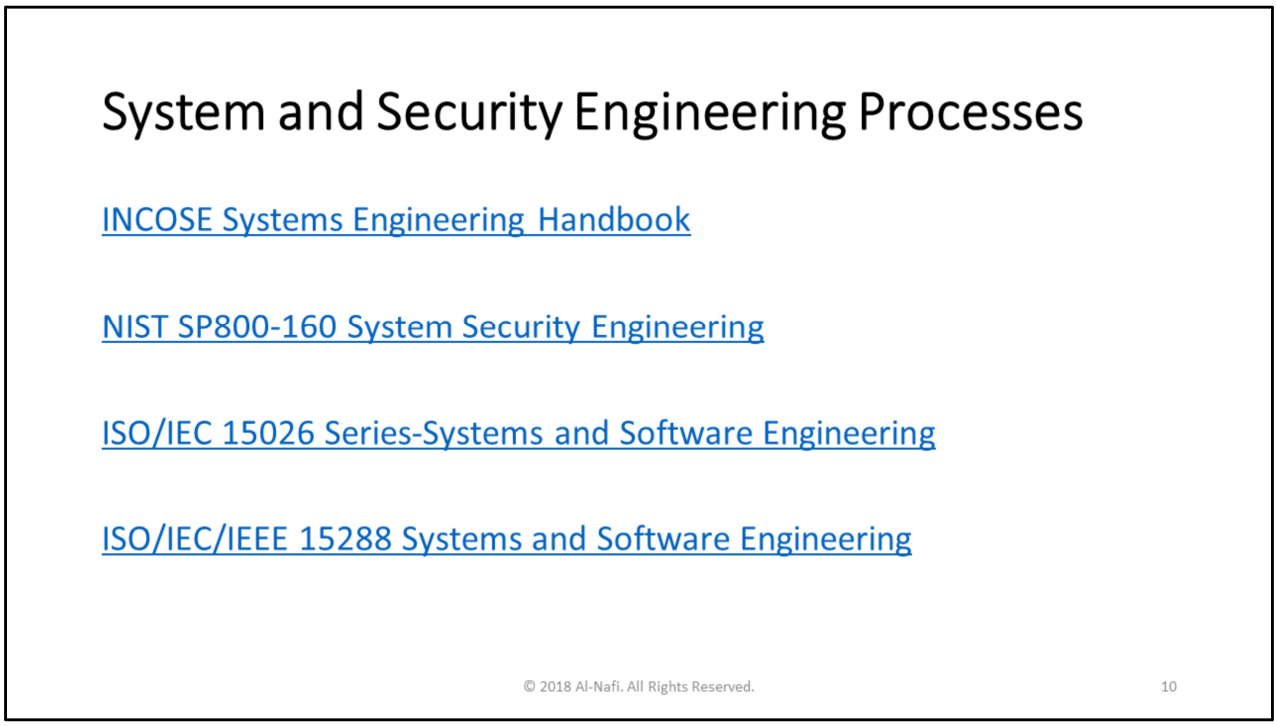
So what is Security Engineering. Simple CIA ☺



© 2018 Al-Nafi. All Rights Reserved.

Older sources such as the System Security Engineering Capability Maturity Model (SSE-CMM) provided systems security specific processes that did not directly map to systems engineering processes. While valuable resources, earlier system security engineering models were difficult to relate to standard engineering and software design processes that limited their adoption in many industries.

The current direction with major standards has been to converge systems security engineering as a specialty engineering discipline under traditional systems engineering processes. This allows for closer alignment between traditional engineering and security engineering. Both the International Council on Systems Engineering (INCOSE) and the National Institute of Standards and Technology (NIST) recognize Systems Security Engineering as a specialty engineering discipline of systems engineering. All systems engineering processes are applicable to systems security engineering and are applied with a systems security perspective. Commonly accepted sources for engineering and security engineering include the following:



INCOSE Systems Engineering Handbook

INCOSE is a not-for-profit membership organization founded to develop and disseminate the interdisciplinary principles and practices that enable the realization of successful systems.

NIST SP800-160 System Security Engineering

This publication addresses the engineering-driven actions necessary to develop more defensible and survivable systems—including the components that compose and the services that depend on those systems. It starts with and builds upon a set of well-established International Standards for systems and software engineering published by the International Organization for Standardization (ISO), the International Electro technical Commission (IEC), and the Institute of Electrical and Electronics Engineers (IEEE) and infuses systems security engineering techniques, methods, and practices into those systems and software engineering activities.

ISO/IEC 15026 Series-Systems and Software Engineering

A series of standards focused on Systems and Software Engineering.

ISO/IEC/IEEE 15288 Systems and Software Engineering

A systems engineering standard defining processes.

NIST SP800-160 vs INCOSE System Engineering

- Business and mission analysis process
- Stakeholder needs and requirements definition process
- System requirements definition process
- Architecture definition process
- Design definition process
- System analysis process
- Implementation process
- Integration process

© 2018 Al-Nafi. All Rights Reserved.

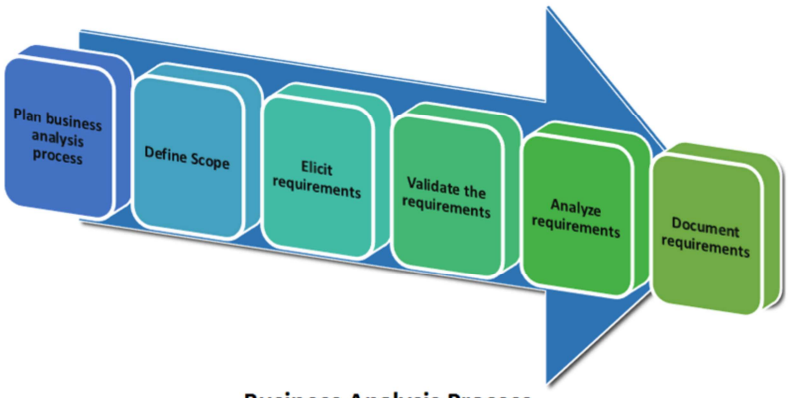
The following processes are defined in the NIST SP800-160 dated November 2016. The processes and process definitions are consistent with the INCOSE Systems Engineering Handbook and easily related to ISO-based standards with some minor differences.

NIST SP800-160 vs INCOSE System Engineering continued

- Verification process
- Transition process
- Operation process
- Maintenance process
- Disposal process

© 2018 Al-Nafi. All Rights Reserved.

Business and mission analysis process



Business Analysis Process

© 2018 Al-Nafi. All Rights Reserved.

Business and mission analysis process:

Helps the engineering team to understand the scope, basis, and drivers of the business or mission problems or opportunities and ascertain the asset loss consequences that present security and protection issues associated with those problems or opportunities.